

Actividad 07

Laboratorio: File Path Traversal

PortSwigger Web Security Academy

Elaborado por: Juan Pablo Casanova De La Madrid

Herramienta utilizada: Burp Suite Community Edition

1. Nombre del laboratorio

File path traversal, simple case

Laboratorio perteneciente a PortSwigger Web Security Academy, dentro de la categoría File path traversal

2. Nivel

Apprentice.

Este nivel corresponde a los laboratorios introductorios de la Web Security Academy, en los que la vulnerabilidad se presenta sin mecanismos adicionales de mitigación, sin filtrado de secuencias "../", sin codificación de caracteres ni validaciones del lado del servidor, por lo que la explotación es directa una vez identificado el parámetro vulnerable.

3. Tipo de explotación

Path Traversal / Directory Traversal (CWE-22: Improper Limitation of a Pathname to a Restricted Directory).

Es una vulnerabilidad del lado del servidor que permite a un atacante manipular la ruta de un archivo solicitado (a través de un parámetro de entrada) para acceder a archivos y directorios almacenados fuera de la carpeta raíz destinada a la aplicación web, aprovechando secuencias de retroceso de directorio ("../").

4. Objetivo del laboratorio

El laboratorio contiene una vulnerabilidad de path traversal en la funcionalidad que muestra las imágenes de los productos de la tienda.

Objetivo: explotar dicha vulnerabilidad para recuperar el contenido del archivo del sistema /etc/passwd, lo que confirma la lectura arbitraria de archivos fuera del directorio previsto por la aplicación y da por resuelto el laboratorio.

Lab: File path traversal, simple case

APPRENTICE
LAB Not solved

This lab contains a path traversal vulnerability in the display of product images.

To solve the lab, retrieve the contents of the `/etc/passwd` file.

ACCESS THE LAB

Figura 1. Descripción y objetivo del laboratorio en PortSwigger Web Security Academy.

5. Explicación técnica de la vulnerabilidad

La aplicación web muestra el catálogo de productos ("We Like To Shop") y cada imagen se sirve dinámicamente mediante un endpoint del tipo:

`GET /image?filename=<nombre_de_archivo>`

El parámetro `filename` es utilizado por el servidor para construir, de forma interna, la ruta física del archivo a devolver, concatenándolo probablemente con una ruta base similar a `/var/www/images/`. El problema es que la aplicación no valida ni sanitiza el valor recibido en `filename` antes de usarlo para acceder al sistema de archivos.

Al no existir validación, es posible sustituir el nombre de archivo esperado (por ejemplo, `31.jpg`) por una secuencia de retroceso de directorios (`../`) seguida de la ruta absoluta de un archivo sensible del sistema operativo. Cada `../` indica al sistema operativo "sube un nivel de directorio", por lo que, al encadenar varias, es posible salir por completo del directorio de imágenes y llegar a la raíz del sistema de archivos (`/`), desde donde se puede referenciar cualquier archivo legible por el usuario con el que corre el servidor web, como `/etc/passwd`.

Esta vulnerabilidad se clasifica dentro de CWE-22 y es una de las causas más comunes de exposición de información sensible (código fuente, archivos de configuración, credenciales, claves privadas, etc.) en aplicaciones web que sirven archivos de forma dinámica.

6. Procedimiento paso a paso

1. Se inicia Burp Suite Community Edition desde Kali Linux, seleccionando "Temporary project in memory" y la configuración por defecto ("Use Burp defaults").

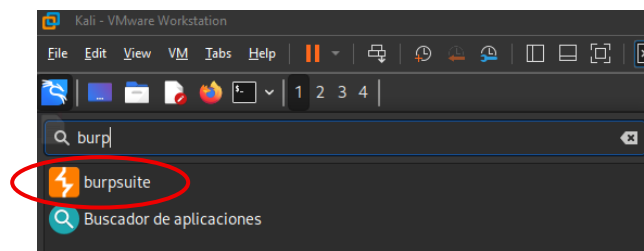


Figura 2. Búsqueda y apertura de Burp Suite en Kali Linux.

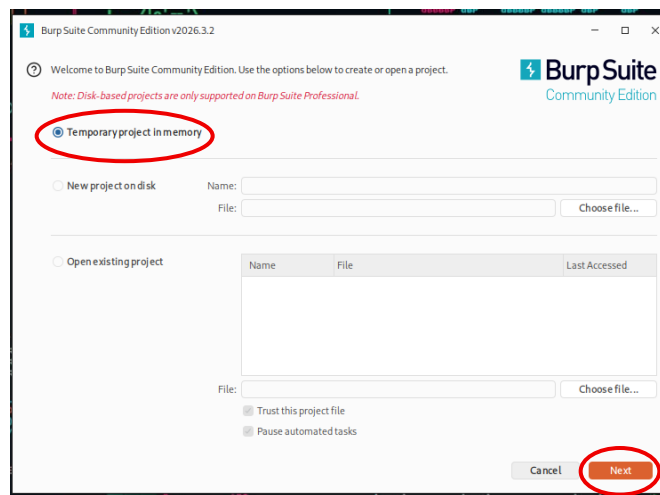


Figura 3. Creación de un proyecto temporal en memoria.

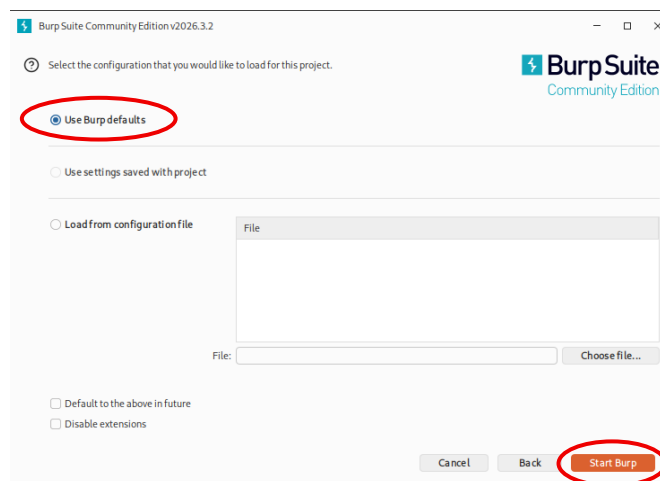


Figura 4. Selección de la configuración por defecto de Burp.

2. Con Burp abierto en la pestaña Proxy > Intercept, se abre el navegador integrado (Chromium embebido) y se accede a la URL del laboratorio proporcionada por PortSwigger.

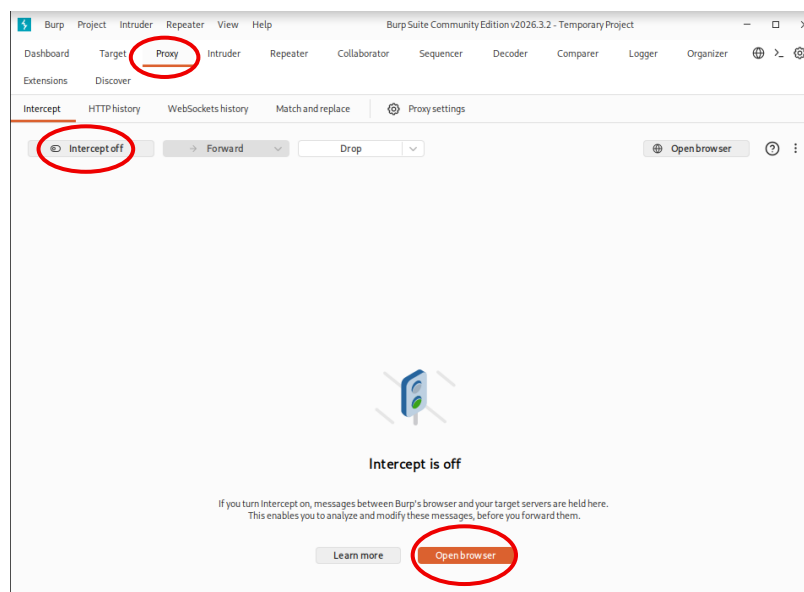


Figura 5. Pestaña Proxy con el Intercept inicialmente apagado.

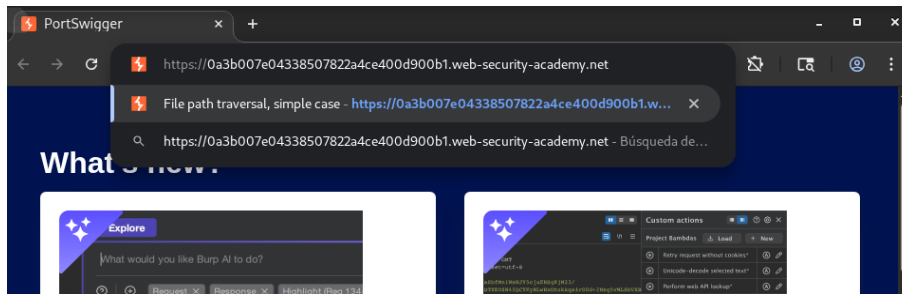


Figura 6. Acceso a la URL del laboratorio "File path traversal, simple case".

- Se activa el Intercept ("Intercept on") y se navega por la tienda; Burp captura las peticiones GET que la página realiza para cargar cada imagen de producto, del tipo /image?filename=NN.jpg, confirmando que el nombre de archivo se maneja mediante un parámetro controlable por el cliente.

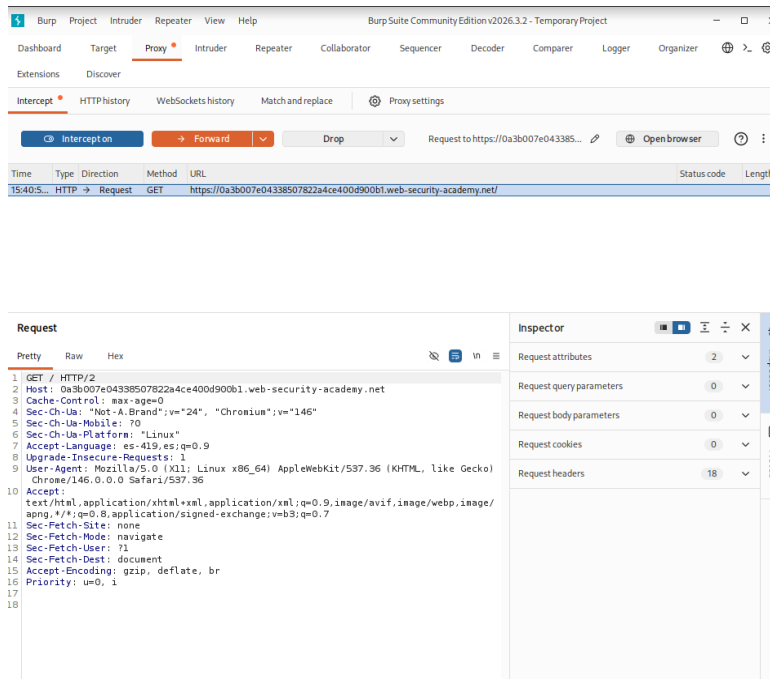


Figura 7. Primera petición GET interceptada al cargar la página principal.

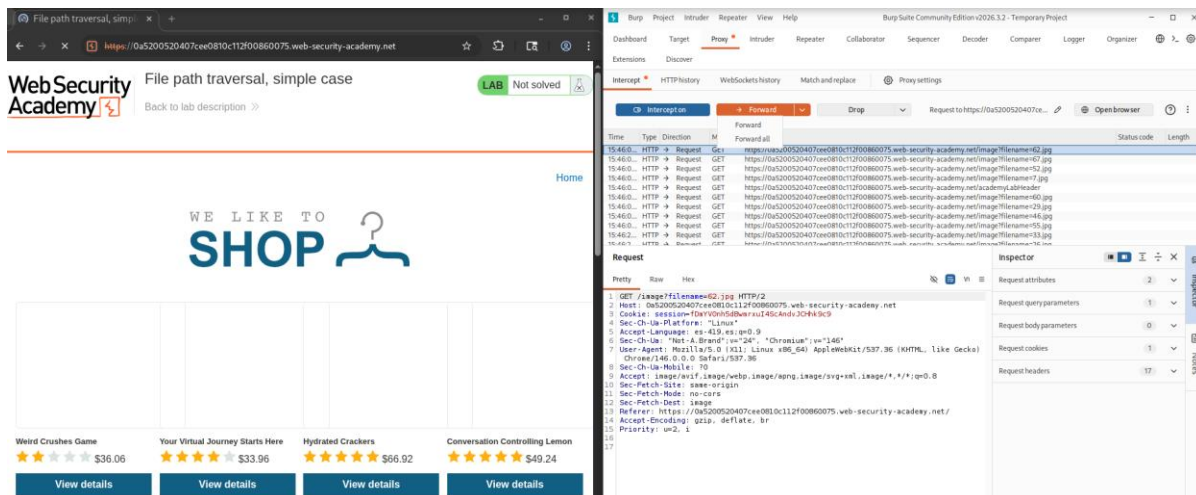


Figura 8. Historial de peticiones interceptadas mostrando el patrón /image?filename=.

4. Se identifica una petición hacia una imagen de producto (filename=31.jpg) y, mediante clic derecho, se envía al módulo Repeater ("Send to Repeater") para poder modificarla y reenviarla libremente.

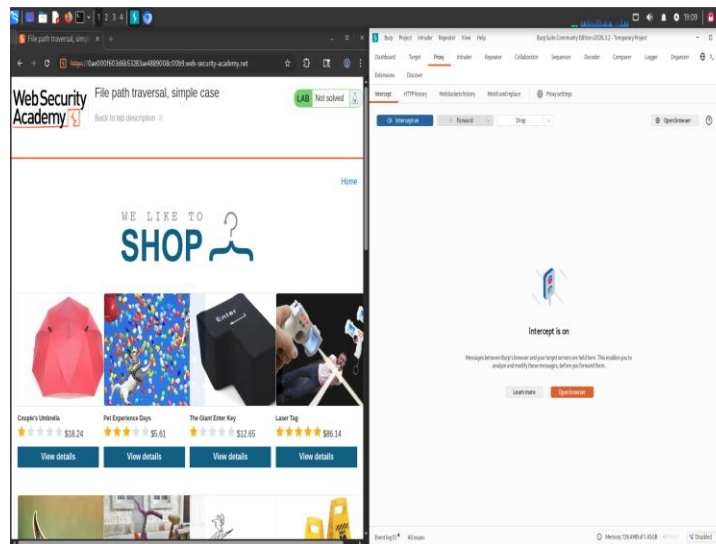


Figura 9. Vista general del entorno con Intercept activo antes de capturar la petición de imagen.

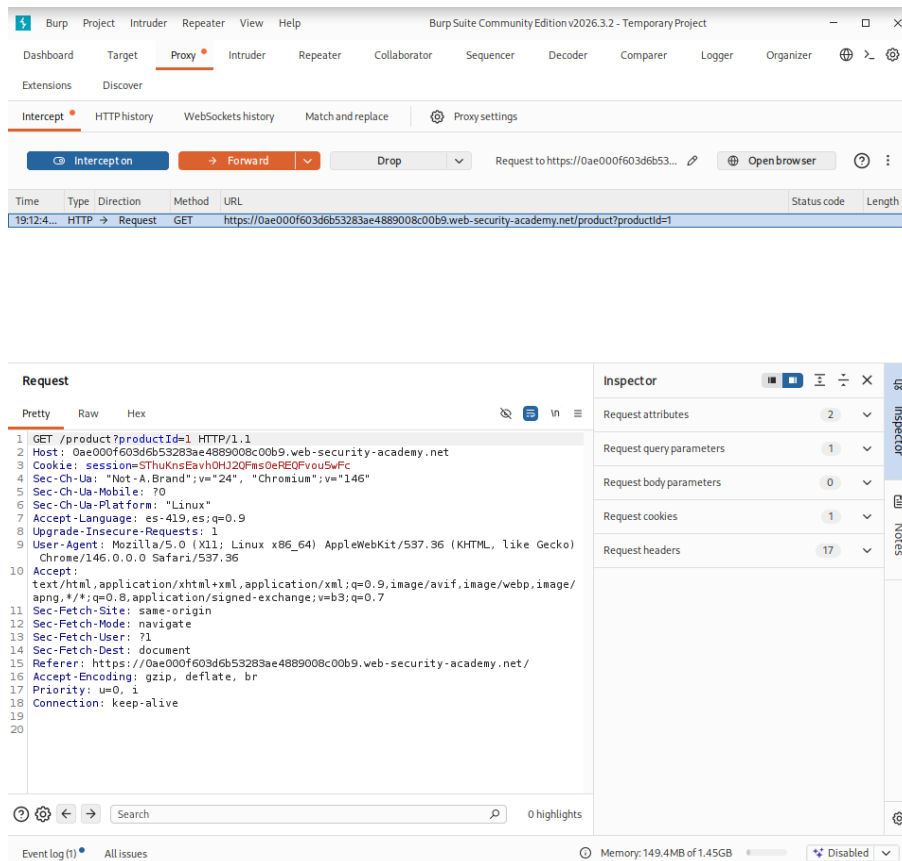


Figura 10. Petición interceptada GET /product?productId=1 (navegación previa dentro de la tienda).

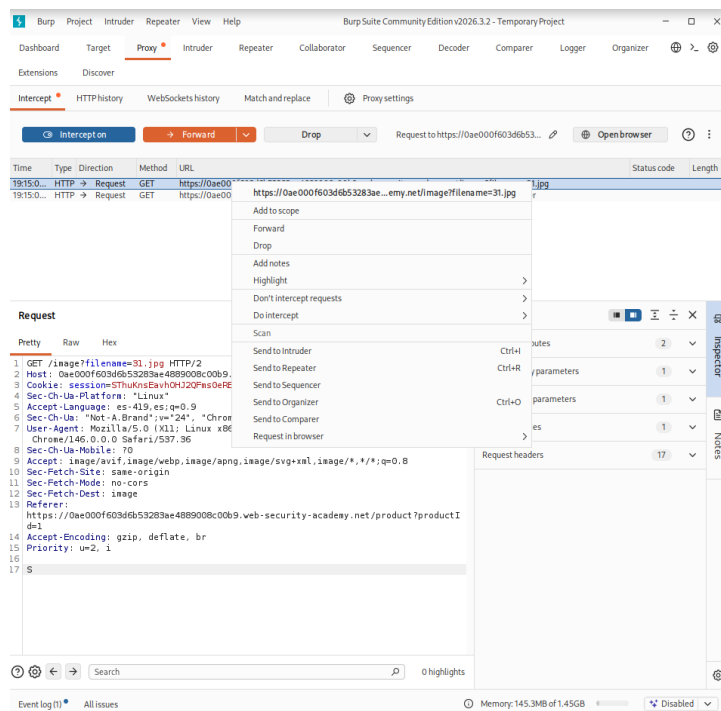


Figura 11. Petición GET /image?filename=31.jpg enviada al Repeater mediante el menú contextual.

- En Repeater se visualiza la petición original, apuntando al parámetro filename=31.jpg.

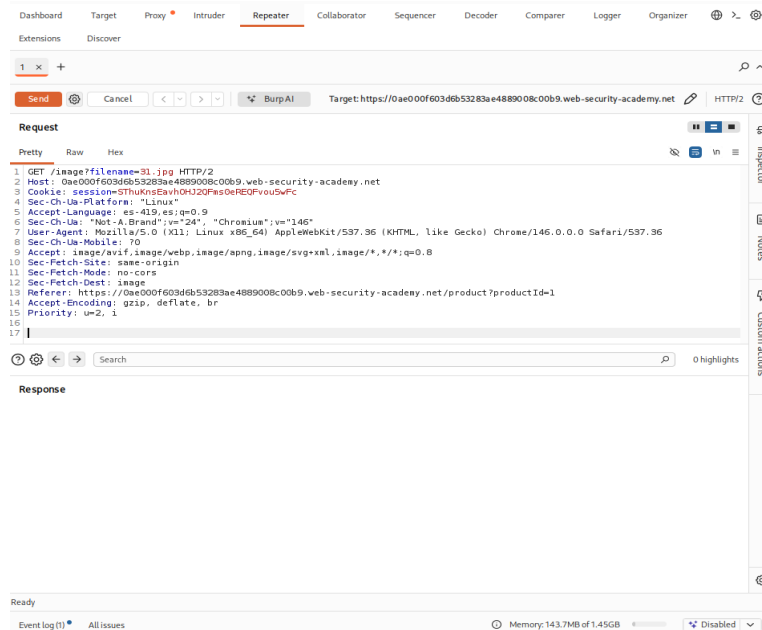


Figura 12. Petición original en Repeater antes de modificar el payload.

- Se reemplaza el valor 31.jpg por la cadena de path traversal ../../../../etc/passwd, con el fin de forzar al servidor a salir del directorio de imágenes y acceder al archivo de credenciales del sistema.

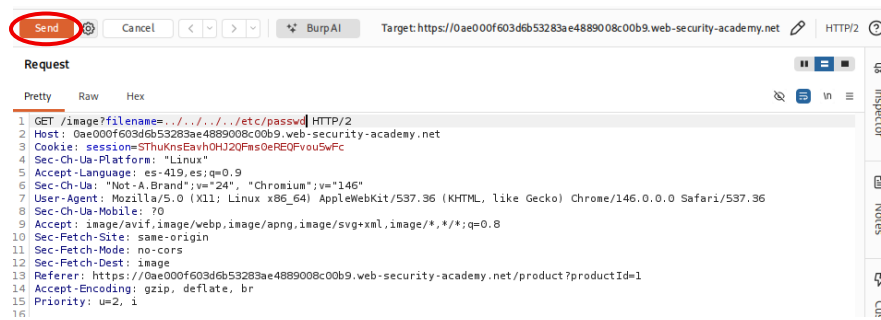


Figura 13. Payload de path traversal inyectado en el parámetro filename.

- Se hace clic en Send y se analiza la respuesta del servidor.
- El servidor responde con código HTTP 200 OK y devuelve en el cuerpo de la respuesta el contenido íntegro del archivo /etc/passwd, confirmando la explotación exitosa de la vulnerabilidad.

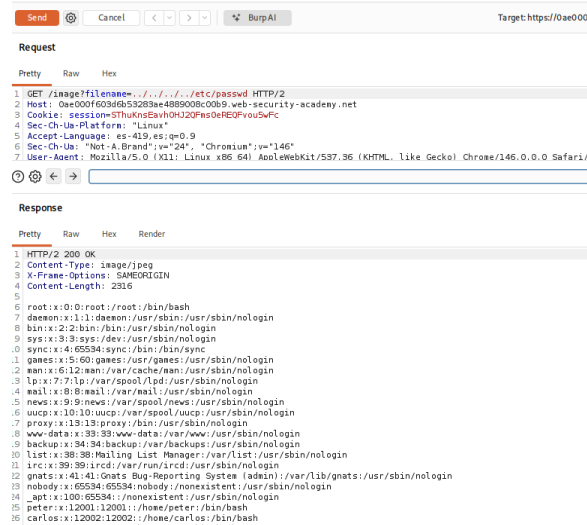
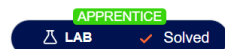


Figura 14. Respuesta vulnerable del servidor mostrando el contenido de /etc/passwd.

- Finalmente, se regresa a la página del laboratorio en PortSwigger, la cual actualiza automáticamente su estado a "Solved", confirmando que el objetivo de la actividad fue completado.

Lab: File path traversal, simple case



This lab contains a path traversal vulnerability in the display of product images.

To solve the lab, retrieve the contents of the `/etc/passwd` file.

Figura 15. Confirmación de laboratorio resuelto ("Solved").

7. Explicación del payload

El payload se construye a partir de dos componentes:

- `../../../../` : cuatro secuencias de retroceso de directorio. Cada `../` instruye al sistema operativo para subir un nivel en la jerarquía de carpetas respecto al directorio base donde la aplicación busca las imágenes (por ejemplo, algo similar a `/var/www/images/`). Se utilizan varias secuencias encadenadas para garantizar que, sin importar la profundidad real del directorio de imágenes, el recorrido llegue hasta la raíz del sistema de archivos (`/`).
- `etc/passwd`: ruta absoluta, ya ubicada en la raíz, hacia el archivo estándar de Unix/Linux que contiene el listado de cuentas de usuario del sistema (nombre de usuario, UID, GID, directorio home y shell asignada). Aunque este archivo no almacena las contraseñas en texto plano, es un objetivo clásico para demostrar path traversal porque es legible por cualquier usuario del sistema y su contenido es fácil de reconocer.

Al concatenar el payload con la ruta base que utiliza la aplicación, el resultado final resuelto por el sistema operativo equivale a `/etc/passwd`, fuera del directorio que la aplicación pretendía exponer.

8. Mitigación recomendada

Para prevenir vulnerabilidades de path traversal como la explotada en este laboratorio, se recomienda aplicar las siguientes medidas, de forma combinada:

- Evitar recibir nombres o rutas de archivo directamente del usuario. Sustituir el parámetro filename por un identificador indirecto que el servidor resuelva internamente contra una lista o base de datos de archivos permitidos.
- Validar y depurar (sanitizar) la entrada: rechazar cualquier valor que contenga secuencias `../`, `..\`, su codificación URL (`%2e%2e%2f`) o caracteres de ruta absoluta, aceptando únicamente los caracteres esperados para un nombre de archivo.
- Ejecutar el servicio con el mínimo privilegio necesario y, cuando sea posible, aislar el proceso mediante chroot jail o contenedores, de forma que, aunque ocurra un escape de directorio, no existan archivos sensibles accesibles.
- Utilizar las funciones o librerías seguras que ofrezca el framework o lenguaje para servir archivos estáticos, en lugar de construir rutas manualmente mediante concatenación de cadenas.
- Reforzar la defensa en profundidad con un WAF (Web Application Firewall) que detecte y bloquee patrones de path traversal, y aplicar monitoreo/alertas sobre accesos a archivos fuera de lo esperado.
- Restringir los permisos de lectura de archivos sensibles del sistema (como `/etc/shadow`) y mantener actualizado el sistema operativo y el software del servidor web.